

CEH v13 ANSWER KEYS

Mock Exam 1 & Mock Exam 2

One-line rationale per question · Scoring bands included

Scoring Benchmark

Study benchmark only — NOT the official EC-Council cut score.

Score /125	Interpretation
106-125	Target range ($\geq 85\%$)
100-105	Close; revise weak areas
94-99	Below target; revision required
<94	Major revision required

Review framework: tally wrong answers by module; any module with ≥ 3 misses $\rightarrow$ re-study that module in the Practice Guide (Exam Traps + Confused Concepts), then redo those question types.

Mock Exam 1 — Answer Key

1. **A** — Non-repudiation prevents denial of an action, typically via digital signatures.
2. **C** — The triangle states that as security increases, functionality and ease of use decrease.
3. **A** — Daisy-chaining uses one compromised system to reach another.
4. **B** — Black-box testing provides no prior knowledge, modeling an external attacker.
5. **C** — IPS is preventive (inline block), backups are recovery, banners are deterrent.
6. **A** — Passive footprinting gathers data without touching the target (e.g., OSINT, WHOIS).
7. **B** — An unrestricted AXFR lets anyone copy the entire zone, leaking all records.
8. **B** — AAAA maps a hostname to an IPv6 address; A is IPv4.
9. **D** — MX records identify a domain's mail servers.
10. **A** — Received headers expose originating IPs and the chain of mail servers.
11. **B** — WHOIS privacy masks registrant/ownership details, not the domain or its DNS.
12. **C** — -sS (SYN) is the half-open/stealth scan; it sends SYN and resets before completing.
13. **D** — On RFC-793 stacks, no response to FIN/NULL/XMAS means open|filtered.
14. **C** — Windows does not follow RFC-793 for stealth scans and returns RST regardless, so all ports look closed.
15. **B** — The ACK scan (-sA) determines filtered vs unfiltered, mapping firewall behavior.
16. **C** — -Pn skips host discovery and treats targets as online.
17. **D** — Windows defaults to TTL 128 (Linux 64, many network devices 255).
18. **A** — UDP silence means open|filtered; a closed port returns ICMP port-unreachable.
19. **A** — Enumeration actively extracts detailed resource and account information.
20. **D** — A null session is an unauthenticated connection to IPC\$ used for enumeration.
21. **A** — 'private' is the classic default read-write string; 'public' is read-only.
22. **B** — VRFY checks whether a given user/mailbox exists on the mail server.
23. **B** — showmount -e lists NFS exports available on a host.
24. **D** — LDAP uses 389; LDAPS uses 636.
25. **B** — CVSS provides the severity score; CVE is the identifier.
26. **C** — A false positive is an alert for a vulnerability that is not actually present.
27. **B** — A false negative misses a real vulnerability, leaving it unaddressed.
28. **C** — Credentialed scans log in to inspect host-level detail accurately.
29. **B** — 9.0–10.0 is Critical in CVSS.
30. **C** — /etc/shadow holds the hashes; /etc/passwd holds account info without hashes.
31. **D** — The SAM database stores local account hashes; NTDS.dit is for AD domain accounts.
32. **C** — Pass-the-hash reuses the NTLM hash directly for authentication.
33. **A** — A golden ticket forges a TGT with the krbtgt hash, granting access to the entire domain.
34. **C** — Mimikatz dumps credentials and performs PtH/PtT/golden-ticket attacks.
35. **B** — Steganography hides the existence of data within another medium such as an image.
36. **C** — Gaining higher privileges (user to SYSTEM/admin) is vertical privilege escalation.
37. **C** — Rainbow tables use precomputed hashes; salting defeats them by making hashes unique.

- 38. B** — A worm self-propagates autonomously; a virus needs a host and a trojan is disguised.
- 39. B** — A crypter encrypts/obfuscates malware to evade AV detection.
- 40. B** — Dynamic analysis executes the sample in a controlled environment to observe behavior.
- 41. C** — Fileless malware abuses trusted tools in memory; behavioral/EDR detection is needed.
- 42. D** — AES (fast) encrypts files; RSA/ECC protects the AES key (hybrid encryption).
- 43. B** — A hypervisor rootkit runs beneath the OS, making it very hard to detect.
- 44. D** — An APT is a stealthy, resourced, long-term, targeted campaign, not a single malware.
- 45. D** — Adware/bundled software is a PUA — a risk, but not confirmed malware.
- 46. B** — Promiscuous mode accepts all Ethernet frames; monitor mode is the wireless equivalent.
- 47. A** — MAC flooding overflows the CAM table, causing the switch to fail open and flood frames.
- 48. D** — The CAM table maps MAC addresses to switch ports; ARP maps IP to MAC on hosts.
- 49. B** — Forged ARP replies for the gateway IP = ARP spoofing; DAI is the Layer-2 defense.
- 50. C** — Wireshark display filters use syntax like 'http and ip.addr==10.0.0.5'.
- 51. D** — SPAN/port mirroring copies traffic to a monitor port for an analyzer.
- 52. A** — A rogue DHCP server assigns malicious config; DHCP snooping blocks unauthorized servers.
- 53. B** — Tailgating is unauthorized following without the victim's awareness/permission.
- 54. D** — Pretexting relies on an invented scenario/story to extract information.
- 55. D** — Posing as IT (authority) plus an urgent outage (urgency) pressures victims to comply.
- 56. C** — BEC impersonates executives to authorize fraudulent transfers.
- 57. C** — DMARC defines the enforcement policy built on SPF and DKIM results.
- 58. D** — DDoS uses many distributed sources (a botnet); DoS is typically single-source.
- 59. A** — A SYN flood leaves half-open connections that exhaust the connection table.
- 60. A** — The spoofed source reflects responses to the victim, and large responses amplify volume.
- 61. D** — Phlashing (permanent DoS) damages/bricks hardware, often via malicious firmware.
- 62. D** — Slowloris holds connections open with slow/partial requests to exhaust server threads.
- 63. C** — HttpOnly blocks JavaScript access, mitigating cookie theft via XSS.
- 64. A** — Fixation sets a known ID before authentication; hijacking takes over an active session.
- 65. C** — Injecting into a TCP session using sequence numbers is network-level hijacking.
- 66. B** — Regenerating the session ID at login invalidates any attacker-preset ID.
- 67. D** — Spoofing = impersonation; hijacking = seizing an already-established session.
- 68. D** — An IDS detects and alerts (passive); an IPS sits inline and can block.
- 69. C** — Anomaly-based detection flags deviations from a learned baseline.
- 70. B** — Benign traffic flagged as malicious is a false positive.
- 71. C** — Fragmentation breaks payloads across packets to evade signature matching.
- 72. B** — HIDS watches one host's activity; NIDS inspects network traffic.
- 73. C** — A honeypot lures attackers; an IDS monitors real production traffic.
- 74. A** — Directory traversal uses ../ to escape the intended web root.
- 75. A** — Document root holds the served website files; server root holds config/executables.

- 76. A** — Reading response headers to identify server software is banner grabbing/fingerprinting.
- 77. D** — SSRF makes the server issue attacker-chosen requests, e.g., to the cloud metadata endpoint.
- 78. C** — Nikto scans web servers for known vulnerabilities and misconfigurations.
- 79. A** — Stored XSS persists on the server (e.g., in a comment) and runs for all viewers.
- 80. A** — CSRF abuses the site's trust in the authenticated user's browser.
- 81. A** — IDOR exposes other users' objects because authorization isn't enforced per object.
- 82. D** — Client-side validation is bypassable; security-critical validation must be server-side.
- 83. D** — Broken Access Control is A01 in the 2021 list.
- 84. C** — SSRF makes the server send requests; CSRF makes the victim's browser send them.
- 85. D** — WSDL describes a web service; UDDI is the registry.
- 86. D** — Output encoding plus CSP are the core XSS defenses.
- 87. B** — Parameterized queries separate data from code; WAFs are only supplemental.
- 88. B** — Time-based blind SQLi uses delays (e.g., SLEEP) to infer data.
- 89. A** — A tautology makes the WHERE clause always true, bypassing authentication.
- 90. D** — UNION-based SQLi requires matching the original query's column count and compatible types.
- 91. C** — sqlmap automates detection, enumeration, and exploitation of SQLi.
- 92. C** — Boolean-based blind SQLi infers data from true/false behavioral differences.
- 93. A** — Verbose DB errors enable error-based SQLi by leaking structure/data.
- 94. B** — WEP uses RC4 with a weak 24-bit IV, making it trivially crackable.
- 95. D** — Rogue AP = unauthorized AP; evil twin = fake AP mimicking a trusted SSID.
- 96. B** — Capturing the handshake enables offline cracking of the WPA2 pre-shared key.
- 97. A** — Enterprise mode (802.1X/EAP with RADIUS) provides per-user, centralized authentication.
- 98. C** — Bluesnarfing steals data; bluejacking sends messages; bluesmacking is DoS.
- 99. C** — The Aircrack-ng suite captures and cracks WEP/WPA keys.
- 100. B** — WPA3-Personal uses SAE, which resists offline dictionary/password attacks.
- 101. A** — Jailbreaking is the iOS term; rooting is the Android equivalent.
- 102. C** — Repackaged apps embed malware into legitimate apps distributed via untrusted stores.
- 103. D** — MDM centrally enforces policy, encryption, and remote wipe.
- 104. B** — CEH frames the mobile attack surface as device, network, and data center/cloud.
- 105. D** — App sandboxing isolates each app's data/resources; escaping it increases impact.
- 106. B** — Weak/guessable/hardcoded passwords is the top OWASP IoT risk.
- 107. D** — OT prioritizes availability and safety of physical processes above confidentiality.
- 108. C** — Mirai infected IoT devices via default credentials to build a DDoS botnet.
- 109. A** — Segmenting/isolating OT from IT is the primary control for insecure legacy ICS protocols.
- 110. C** — MQTT is a lightweight pub/sub messaging protocol common in IoT.
- 111. A** — IaaS gives the customer the most responsibility (OS, apps, data).
- 112. A** — Customers always own their data, identities, and configuration.

- 113. D** — 169.254.169.254 is the cloud instance metadata service that can leak IAM credentials.
- 114. A** — Containers share the host kernel (lightweight); VMs run full OSes on a hypervisor.
- 115. B** — Misconfiguration, such as public buckets/open settings, is the top cloud exposure cause.
- 116. A** — A wrapping attack tampers with a SOAP message so the altered request is processed as valid.
- 117. D** — AES is the standard symmetric block cipher; RSA/DH are asymmetric, SHA-256 is a hash.
- 118. D** — Signing uses the signer's private key; verification uses the signer's public key.
- 119. A** — For confidentiality, encrypt with the recipient's (Bob's) public key.
- 120. A** — Unsalted hashes enable rainbow-table lookups; salting defeats precomputed tables.
- 121. B** — RC4 is a stream cipher; AES, 3DES, and Blowfish are block ciphers.
- 122. C** — CA-signed certs anchor trust in a CA chain; self-signed lack third-party trust.
- 123. A** — Shor's algorithm efficiently factors/solves discrete logs, breaking RSA and ECC.
- 124. A** — A 51% attack gives majority control, allowing transaction rewrites.
- 125. B** — HMAC gives integrity and authentication via a shared key but not non-repudiation.

Mock Exam 2 — Answer Key

1. **A** — Integrity ensures data is not modified by unauthorized parties.
2. **C** — A hacktivist attacks for ideological/political causes.
3. **A** — Partial knowledge plus some access models a gray-box (partially informed) test.
4. **B** — A standard is a mandatory rule; a guideline is only a recommendation.
5. **C** — STRIDE's E is Elevation of Privilege.
6. **A** — WHOIS returns domain registration information.
7. **B** — nslookup supports interactive mode with 'set type=...'.
8. **B** — site: restricts the search to a specific domain.
9. **D** — ICMP Type 3 Code 13 = communication administratively prohibited, indicating filtering.
10. **A** — SPF lists authorized sending servers for a domain.
11. **B** — Shodan indexes internet-connected devices, enabling passive discovery.
12. **C** — -sV performs service/version detection; -O is OS detection.
13. **D** — The connect scan (-sT) completes the handshake and needs no root, but is easily logged.
14. **C** — An XMAS scan sets FIN, PSH, and URG.
15. **B** — In an ACK scan, an RST means the port is unfiltered; it does not reveal open/closed.
16. **C** — -D adds decoys to obscure the real source IP.
17. **D** — Many network devices default to TTL 255.
18. **A** — UDP services require a UDP scan (-sU).
19. **A** — SMB over TCP/445 is central to Windows share/domain enumeration.
20. **D** — nbtstat -A queries the remote NetBIOS name table using an IP address.
21. **A** — The MIB is the database of managed objects; an OID identifies a single object.
22. **B** — ldapsearch queries LDAP/AD directory objects such as users and groups.
23. **B** — EXPN expands a mailing list; VRFY verifies a single user.
24. **D** — 'public' is the default read-only community string.
25. **B** — MITRE maintains CVE; FIRST maintains CVSS; NIST runs the NVD.
26. **C** — Transfer shifts the risk's impact to another party (e.g., insurance).
27. **B** — A false negative hides a real vulnerability, creating a false sense of security.
28. **C** — The NVD (NIST) aggregates CVE/CVSS/CWE/CPE and references.
29. **B** — CWE classifies weakness types; CVE identifies specific instances.
30. **C** — Hashcat performs GPU-accelerated offline cracking; Hydra attacks online services.
31. **D** — NTDS.dit stores AD domain account data on the domain controller.
32. **C** — A silver ticket forges a service ticket for one specific service.
33. **A** — Password spraying tries one password across many users to evade lockout thresholds.
34. **C** — LM uppercases, splits into two 7-char halves, and uses no salt.
35. **B** — Clearing logs to hide evidence is part of covering tracks.
36. **C** — A root-owned SUID binary runs with owner (root) privileges, enabling escalation if misused.
37. **C** — A trojan is disguised and does not self-replicate; viruses and worms replicate.
38. **B** — A dropper carries and installs the malware payload.

- 39. B** — Static analysis inspects the file without running it.
- 40. B** — Double extortion combines encryption with the threat of leaking exfiltrated data.
- 41. C** — A metamorphic virus rewrites its own code; a polymorphic one encrypts/changes its signature.
- 42. D** — Compromising a vendor to reach its customers is a supply-chain attack.
- 43. B** — A packer compresses/obscures an executable to hinder analysis and AV detection.
- 44. D** — Passive sniffing only observes; active sniffing manipulates/injects.
- 45. D** — ARP resolves IPv4 addresses to MAC addresses on the local segment.
- 46. B** — Switches forward unicast to the destination port, so extra steps (e.g., ARP spoofing) are needed.
- 47. A** — ARP cache poisoning redirects the victim's traffic through the attacker (MITM).
- 48. D** — Port security limits/locks MACs per port, mitigating CAM-table flooding.
- 49. B** — Capture (BPF) filters limit recording; display filters only change what is shown.
- 50. C** — Monitor mode captures all wireless frames; promiscuous is the wired equivalent.
- 51. D** — Dumpster diving retrieves sensitive info from discarded materials.
- 52. A** — Baiting exploits curiosity with infected media such as USB drives.
- 53. B** — Vishing is voice/phone-based social engineering.
- 54. D** — Targeting a high-value executive is whaling (a form of spear phishing).
- 55. D** — MFA blocks account access even when a password is phished.
- 56. C** — DoS attacks target availability.
- 57. C** — Smurf abuses ICMP echo to a broadcast with the victim's spoofed source.
- 58. D** — The C2 server coordinates the bots in a botnet.
- 59. A** — Sinkholing redirects traffic for analysis; blackholing drops it entirely.
- 60. A** — A LAND attack uses identical source and destination address/port.
- 61. D** — HTTP floods mimic legitimate traffic, making filtering difficult.
- 62. D** — SameSite limits cross-site cookie sending, helping prevent CSRF.
- 63. C** — Stealing/using an application session ID (cookie) is application-level hijacking.
- 64. A** — Encrypting traffic with TLS prevents token capture on the wire.
- 65. C** — Blind hijacking requires guessing valid sequence numbers without observing traffic.
- 66. B** — Short timeouts plus token rotation limit the window for stolen-token reuse.
- 67. D** — An IPS is inline and can block; an IDS only detects/alerts.
- 68. D** — Signature-based detection matches known patterns but misses zero-days.
- 69. C** — DNS tunneling hides other traffic inside DNS to bypass filtering.
- 70. B** — A false negative means a real attack is missed entirely.
- 71. C** — Stateful firewalls track connection state across packets.
- 72. B** — A honeypot deliberately lures attackers; an IDS monitors production traffic.
- 73. C** — Directory listing and default credentials are classic misconfigurations.
- 74. A** — Three-tier = presentation, application/logic, and data layers.
- 75. A** — Defacement alters content, violating integrity.
- 76. A** — Encoded ../ sequences reading system files is directory traversal from poor path validation.
- 77. D** — Server root holds config/binaries; document root holds served content.

- 78. C** — XSS injects script that runs in victims' browsers.
- 79. A** — Reflected XSS echoes the payload from the request (e.g., a malicious link).
- 80. A** — Including/executing a remote file via user input is RFI; LFI uses local files.
- 81. A** — Untrusted updates/deserialization fall under A08 Software and Data Integrity Failures.
- 82. D** — CSRF tokens plus SameSite cookies are the core CSRF defenses.
- 83. D** — Making the server reach internal resources on the attacker's behalf is SSRF.
- 84. C** — REST uses HTTP methods and commonly JSON; SOAP is an XML protocol.
- 85. D** — SQLi arises when user data is interpreted as part of the query (code).
- 86. D** — Out-of-band SQLi uses a different channel (e.g., DNS) to retrieve data.
- 87. B** — A consistent delay from SLEEP indicates time-based blind SQLi.
- 88. B** — Second-order SQLi executes later when stored input is used in another query.
- 89. A** — WAFs can be bypassed; parameterized queries fix the actual flaw.
- 90. D** — sqlmap automates SQLi, including enumerating databases with --dbs.
- 91. C** — Keyword filters that don't normalize input are bypassed by case/comment tricks.
- 92. C** — WPA2 uses AES-CCMP; WEP uses RC4 and WPA uses TKIP.
- 93. A** — BSSID is the AP's MAC address; SSID is the network name.
- 94. B** — An evil twin mimics a legitimate SSID to lure clients.
- 95. D** — Reaver brute-forces the 8-digit WPS PIN to recover the passphrase.
- 96. B** — Bluejacking sends unsolicited messages; bluesnarfing steals data.
- 97. A** — MACs are visible in frames and easily spoofed, so filtering is only supplemental.
- 98. C** — SAE in WPA3-Personal resists offline dictionary attacks on captured handshakes.
- 99. C** — War driving maps Wi-Fi while moving; war chalking marks found networks with symbols.
- 100. B** — Rooting is the Android term; jailbreaking is the iOS equivalent.
- 101. A** — MDM enables policy enforcement and remote wipe.
- 102. C** — Untrusted app sources plus excessive permissions are a core mobile risk.
- 103. D** — A tethered jailbreak needs a PC at each boot and does not persist alone.
- 104. B** — Containerization isolates work data from personal data.
- 105. D** — SCADA = supervisory control and data acquisition, used to control physical processes.
- 106. B** — A PLC (programmable logic controller) controls physical equipment.
- 107. D** — Stuxnet targeted PLCs to damage centrifuges.
- 108. C** — Hardcoded passwords enable mass compromise (e.g., Mirai-style botnets).
- 109. A** — Device-to-gateway routes device traffic through a local gateway.
- 110. C** — SaaS delivers ready-to-use applications (e.g., webmail).
- 111. A** — A cloud broker intermediates service use/performance/delivery.
- 112. A** — Side-channel attacks exploit shared physical resources (e.g., cache timing).
- 113. D** — MITC abuses stolen sync tokens to hijack cloud accounts without the password.
- 114. A** — Containers share the host kernel and are lighter than VMs.
- 115. B** — Excessive RBAC permissions are a top Kubernetes risk.
- 116. A** — Hash functions are one-way; encryption is reversible with a key.
- 117. D** — Diffie-Hellman is a key-exchange algorithm.
- 118. D** — Verification uses the signer's (Alice's) public key.

- 119. A** — Harvest-now-decrypt-later captures ciphertext today to decrypt once quantum computers mature.
- 120. A** — The RA verifies identity; the CA issues/signs the certificate.
- 121. B** — A self-signed certificate lacks a trusted CA chain, triggering warnings.
- 122. C** — Downgrade attacks like POODLE target old SSL; disable it and enforce modern TLS.
- 123. A** — The birthday attack exploits collision probability in hash functions.
- 124. A** — An eclipse attack isolates a node from legitimate peers.
- 125. B** — AES is a block cipher; RC4 is a stream cipher.